הצעה PUB-03: שמירת שם וטלפון של טכנאי שהוקלדו על ידי ספק

מסמך	הצעה PUB-03: שמירת שם וטלפון של טכנאי שהוקלדו על ידי ספק
נתיב המקור	docs/security/PROPOSAL_PUB03_PENDING_TECHNICIAN_RETENTION.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

הצעה (אנגלית): שמירה ומחיקה של פרטי טכנאי שטרם אושר; האפשרות שנבחרה יושמה לפי החלטת הבעלים מ-21.10.2026.

Proposal PUB-03: retention of vendor-typed technician name and phone (not implemented)

Source: `private/planning/SECURITY_REVIEW_PUBLIC_2026-10-20.md`, finding PUB-03 (Low, privacy / data minimisation). Status: PROPOSAL, owner decision needed. No code, no migration in this change.

Update SECFIX2-295: option A and the cap are IMPLEMENTED; owner decision 2026-10-21: defaults 90 days and 10 per vendor (`access.external.pending_retention_days`, `access.external.pending_max_per_vendor`; a saved 0 switches either off): `services/pending_retention.py`, `access_arrival._new_technician`, tests `test_secfix2_pub03_pending_retention.py`. The 60-day reminder of point 2 is served by the existing needs-review report (from day 30, `directory.review_pending_days`); point 6 was already true (lead decision 6, 2026-10-18). Values and screens: `docs/security/SECFIX2_295_OWNER_SWITCHES.md` sections 2 and 5. The title's "(not implemented)" refers to the original proposal.

1. Problem: `access_arrival._new_technician` inserts an inactive `ticket_contacts` row (clear name, `phone_e164`, `phone_key`) plus an `access_pending_contacts` row for a number typed by a vendor on a public link. If no manager accepts or rejects it, nothing ever deletes it, and it travels in every backup.
2. Option A (recommended): a janitor step deletes a pending row, and its inactive contact row when nothing else references it, once it is older than 90 days without a decision. A manager reminder (needs-review) fires at 60 days so a real request is not lost.
3. Option B: 30 days, shorter and more private, but a slow approval loop (holidays) loses real requests and the vendor must retype.
4. Option C: 180 days, closest to the yearly needs-review cadence; leaves third-party numbers longer than the purpose needs.
5. Cap, independent of the period: at most 10 pending technicians per vendor; the 11th typed person is refused with the existing `Refused(429)` vocabulary, so a link holder cannot plant unbounded rows between janitor runs.
6. Decided rows (accepted or rejected) follow the existing rules; a rejected pending contact is deleted at rejection time instead of waiting for the janitor.
7. Deletion must be in the same transaction for both tables, write one audit row with counts only (never a name or number), and never touch an active contact or one referenced by a grant, ticket event or outbox row.

8. Placement: a self-throttled step called from `main.janitor_tick`, same pattern as `tickets/costs_retention.janitor` (every 10 min, failure logged by type, never stops the tick).
9. Tests to write when approved: row older than N days is removed with its contact; a referenced contact stays; a young row stays; the cap refuses the 11th; the audit row carries counts only.
10. Needs from the owner: choose A, B or C, confirm the cap, confirm the manager reminder day. A setting under `access.pending_retention_days` (default per the choice) keeps it adjustable without a release.